



# PROJECT PROPOSAL

GVHD: TS. Nguyễn Ngọc Tự

|                     |                                                                                                                                   |
|---------------------|-----------------------------------------------------------------------------------------------------------------------------------|
| Sinh viên thực hiện | <b>Sinh viên 1</b><br>MSSV: 23521746<br>Họ tên: Nguyễn Viết Tùng<br><b>Sinh viên 2</b><br>MSSV: 23521757<br>Họ tên: Nguyễn Lộc Tỷ |
|---------------------|-----------------------------------------------------------------------------------------------------------------------------------|

**FaaS**Warden: Giải pháp bảo mật CI/CD Pipeline và giám sát dựa trên trí tuệ nhân tạo cho kiến trúc Serverless.

## I. Nhận định & Ý tưởng

Trong kỷ nguyên điện toán đám mây, các ứng dụng hướng chức năng (Function-as-a-Service - FaaS, hay còn gọi là kiến trúc Serverless) đang trở thành xu thế nhờ khả năng co giãn cực hạn (Scale-to-Zero) cùng tốc độ triển khai khủng khiếp. Cũng vì lẽ đó, nó tạo ra những thách thức mới về mặt kinh tế và tài nguyên mà các cơ chế bảo mật truyền thống (Rule-based) không thể giải quyết.

Nhóm đề xuất **FaaS**Warden, một khung giải pháp bảo mật toàn diện cho kiến trúc Serverless, kết hợp giữa việc kiểm soát an toàn trong quy trình triển khai (Shift Left) và giám sát thông minh trong thời gian thực (Shift Right). Đề tài kết hợp ba lĩnh vực đang phát triển mạnh: Serverless Security, DevSecOps và Machine Learning for Security.

Ở giai đoạn triển khai, hệ thống quét mã nguồn và các tệp tin cấu hình hạ tầng (Infrastructure-as-Code) để phát hiện cấu hình sai lệch và tự động áp dụng resource quota (memory, timeout) nhằm ngăn chặn Denial-of-Resource. Khi vận hành, mô hình học máy đặt tại API Gateway thu thập thông số (telemetry) với độ trễ thấp và phát hiện tấn công Denial-of-Wallet dựa trên hành vi bất thường. Khi này, hệ thống lập tức cảnh báo và/hoặc tự động phản ứng; đồng thời dữ liệu sẽ dùng để cải thiện các lần triển khai sau, tạo thành vòng lặp bảo mật khép kín.

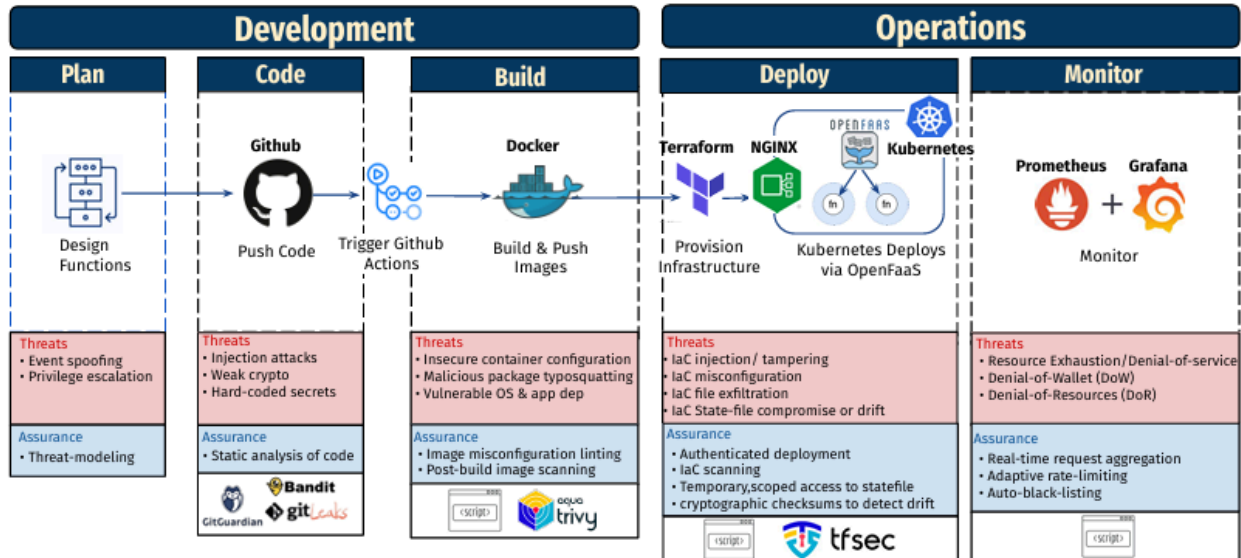
Mục tiêu là chuyển từ giám sát truyền thống (rule-based monitoring) sang giám sát dựa trên hành vi (behavior-based runtime protection).

Nhóm sẽ tập trung vào nghiên cứu pha Monitor, và cố gắng triển khai bảo mật càng chi tiết càng tốt với các pha còn lại của DevSecOps Pipeline. Đề tài hướng tới việc chứng

minh rằng giám sát dựa trên mô hình học máy có thể cải thiện đáng kể bảo mật runtime cho Serverless mà không gây overhead lớn cho hệ thống.

## II. Vấn đề

Bài báo [FaaSGuard: Secure CI/CD for Serverless Applications – An OpenFaaS Case Study \(arXiv:2509.04328\)](#) đề xuất đã đề xuất một mô hình bảo vệ xuyên suốt 5 phase của quy trình DevSecOps:



Tuy nhiên, nhóm nhận thấy pha Monitor trong bài báo hiện chủ yếu dừng ở việc thu thập log, theo dõi telemetry và phát hiện dựa trên các quy tắc cố định. Cách tiếp cận này khó thích ứng với những tấn công có hành vi biến đổi liên tục, đặc biệt là Denial-of-Wallet, một rủi ro mang tính đặc thù của mô hình Serverless. Bên cạnh đó, hướng triển khai này sẽ gặp nhiều trở ngại khi áp dụng vào các nền tảng Managed Services như AWS Lambda hay Cloudflare Workers, do việc can thiệp sâu vào hạ tầng máy chủ và luồng xử lý nội bộ của nhà cung cấp đám mây thường bị giới hạn nghiêm ngặt cả về kỹ thuật lẫn quyền truy cập.

Do đó, FaaSWarden được đề xuất như một phần mở rộng của FaaSGuard, bổ sung lớp giám sát thông minh sử dụng AI nhằm nâng cao khả năng phát hiện và phản ứng trong runtime. Thay vì can thiệp trực tiếp vào hạ tầng của nhà cung cấp cloud, FaaSWarden đặt một lớp API Gateway trung gian để trừu tượng hóa dữ liệu (Telemetry Abstraction), giúp hệ thống thích nghi với bất cứ nguồn dữ liệu nào (Prometheus, Grafana, AWS CloudTrail...). Dữ liệu sau đó được đưa vào một mô hình với kiến trúc LightGBM / XGBoost (sở hữu hiệu năng cao và khả năng phân loại tốt) để phát hiện hành vi bất thường theo thời gian thực.



### III. Dataset

Nhóm dự kiến sử dụng hai nguồn dữ liệu:

#### 1. Dataset tự sinh (Synthetic Dataset)

Nhóm đề xuất triển khai môi trường thực nghiệm OpenFaaS kết hợp API Gateway nhằm thu thập dữ liệu thời gian thực qua Prometheus. Quá trình sinh dữ liệu sẽ đan xen giữa lưu lượng hợp lệ và các kịch bản tấn công Denial-of-Wallet (DoW) tinh vi như: tấn công nhỏ giọt (Leeching) để lẩn tránh hệ thống phòng thủ, khai thác tài nguyên bằng tệp đầu vào dung lượng lớn, và ép lỗi logic (ReDoS/XML Bomb) nhằm tối đa hóa thời gian xử lý. Hệ thống sẽ trích xuất trực tiếp các vector đặc trưng hành vi và tài nguyên — điển hình như độ trễ (RTT), thời gian chạy hàm (FunctionDuration), số lượng hàm kích hoạt đồng thời (ActiveFunctionsAtRequest), cùng mức tiêu thụ CPU/RAM — sau đó gán nhãn tự động dựa trên khung thời gian (time-window) của kịch bản tấn công, từ đó tạo ra tập dữ liệu đa chiều, chất lượng cao để huấn luyện mô hình LightGBM/XGBoost.

#### 2. Dataset tham khảo

[DDoS Evaluation Dataset \(CIC-DDoS2019\)](#)

### IV. Tài liệu tham khảo

- Barrak, A., Ksontini, E., Atike, R., & Jaafar, F. (2025, September 4). *FaaS-Guard: Secure CI/CD for serverless applications – An OpenFaaS case study*. arXiv. <https://doi.org/10.48550/arXiv.2509.04328>
- Dorsett, M. et al. (2025). *A comprehensive review of denial of wallet attacks in serverless architectures*. arXiv. <https://doi.org/10.48550/arXiv.2508.19284>
- Kelly, D., Glavin, F. G., & Barrett, E. (2021). Denial of wallet—Defining a looming threat to serverless computing. *Journal of Information Security and Applications*, 60, 102843. <https://doi.org/10.1016/j.jisa.2021.102843>
- Kelly, D., Glavin, F. G., & Barrett, E. (2023). DoWTS – Denial-of-wallet test simulator: Synthetic data generation for preemptive defence. *Journal of Intelligent Information Systems*, 60(1), 325–348. <https://doi.org/10.1007/s10844-022-00735-3>
- Ortega Candel, J. M., Mora Gimeno, F. J., & Mora Mora, H. (2024). Generation of a dataset for DoW attack detection in serverless architectures. *Data in Brief*, 52, 109921. <https://doi.org/10.1016/j.dib.2023.109921>
- Suvra, D. K. (2025). *An efficient real time DDoS detection model using machine learning algorithms*. arXiv. <https://doi.org/10.48550/arXiv.2501.14311>